

핵심 네트워크

04 보안



목차

—
보안이 무엇인지
알아봅니다.

01 보안

02 해시

03 쿠키

04 세션

05 토큰

06 JWT

07 캐시

01

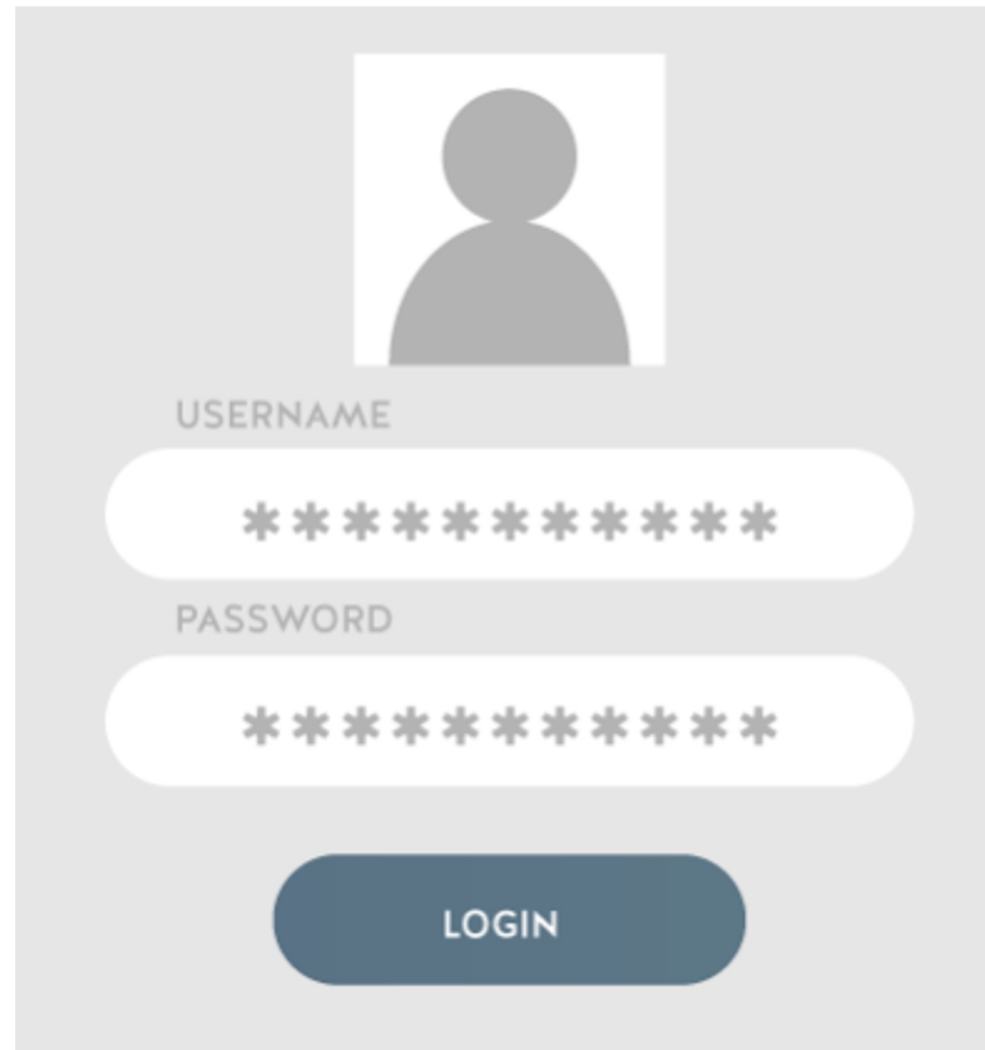
보안

④ 보안



승인되지 않은 액세스나 오용, 오동작, 수정, 파괴, 부적절한 노출
등으로부터 보호하는 프로세스

④ 인증(Authentication)



The illustration shows a login interface on a light gray background. At the top center is a white square containing a gray silhouette of a person's head and shoulders. Below this is the label 'USERNAME' in a small, gray, sans-serif font. Underneath the label is a white, rounded rectangular input field containing ten asterisks. Below the input field is the label 'PASSWORD' in the same small, gray, sans-serif font. Underneath the label is another white, rounded rectangular input field, also containing ten asterisks. At the bottom center of the form is a dark blue, rounded rectangular button with the word 'LOGIN' in white, uppercase, sans-serif font.

사용자의 신원을 검증하는 프로세스

☑ 대표적 인증 방식

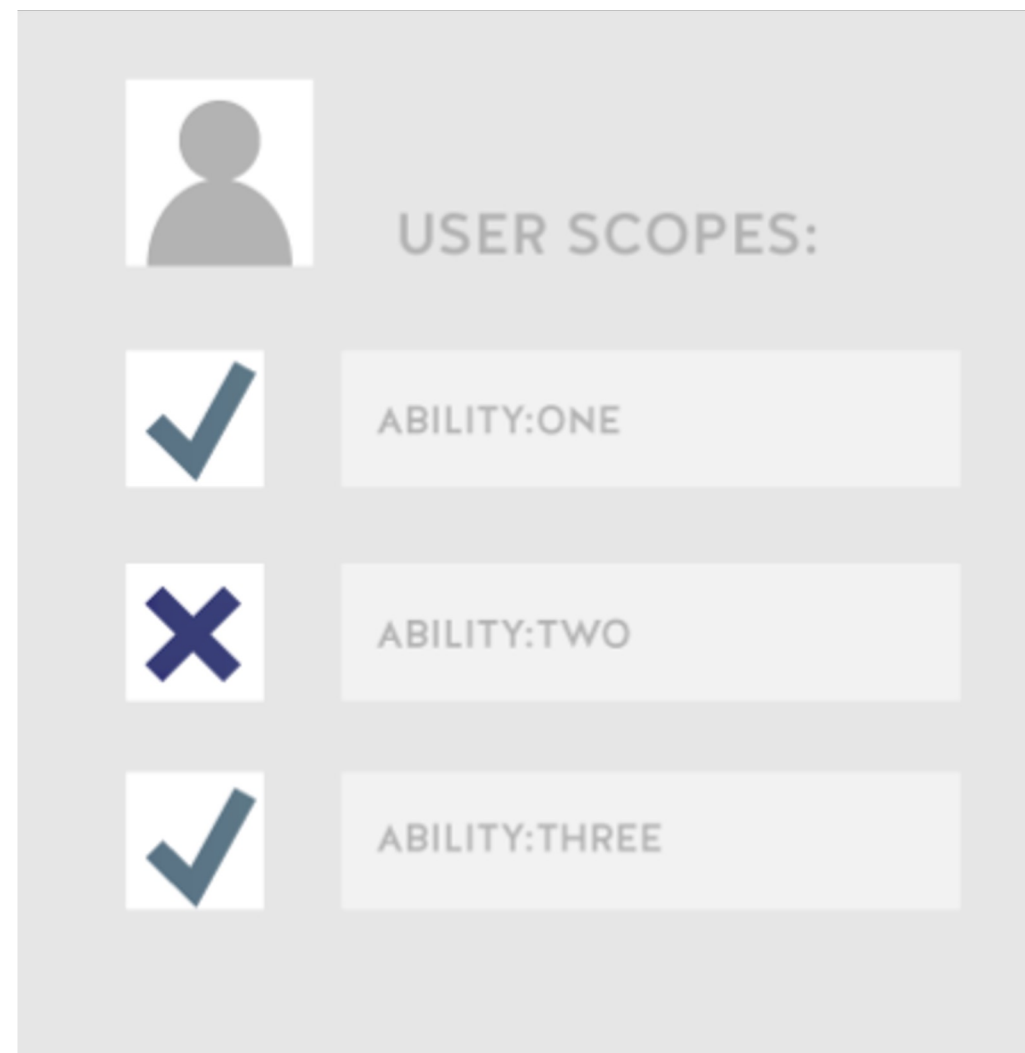
인증 방식	내용
비밀번호	사용자가 데이터를 올바르게 입력하면 시스템은 정보가 유효하다고 판단하고 액세스를 허용함 (가장 많이 사용되는 인증 요소)
일회용 핀	단일 세션이나 트랜잭션 에 한하여 액세스를 허용함
인증 앱	액세스를 허용하는 외부 기관을 통해 보안 코드를 생성함 ex) 휴대폰 인증서
생체 인식	사용자가 시스템에 액세스 하기 위해 지문이나 망막 스캔을 제출함 ex) Face ID, 지문 인식

✍ 용어 해설

트랜잭션
(transaction)

쪼갤 수 없는 업무 처리의 최소
단위.

④ 인가(Authorization)

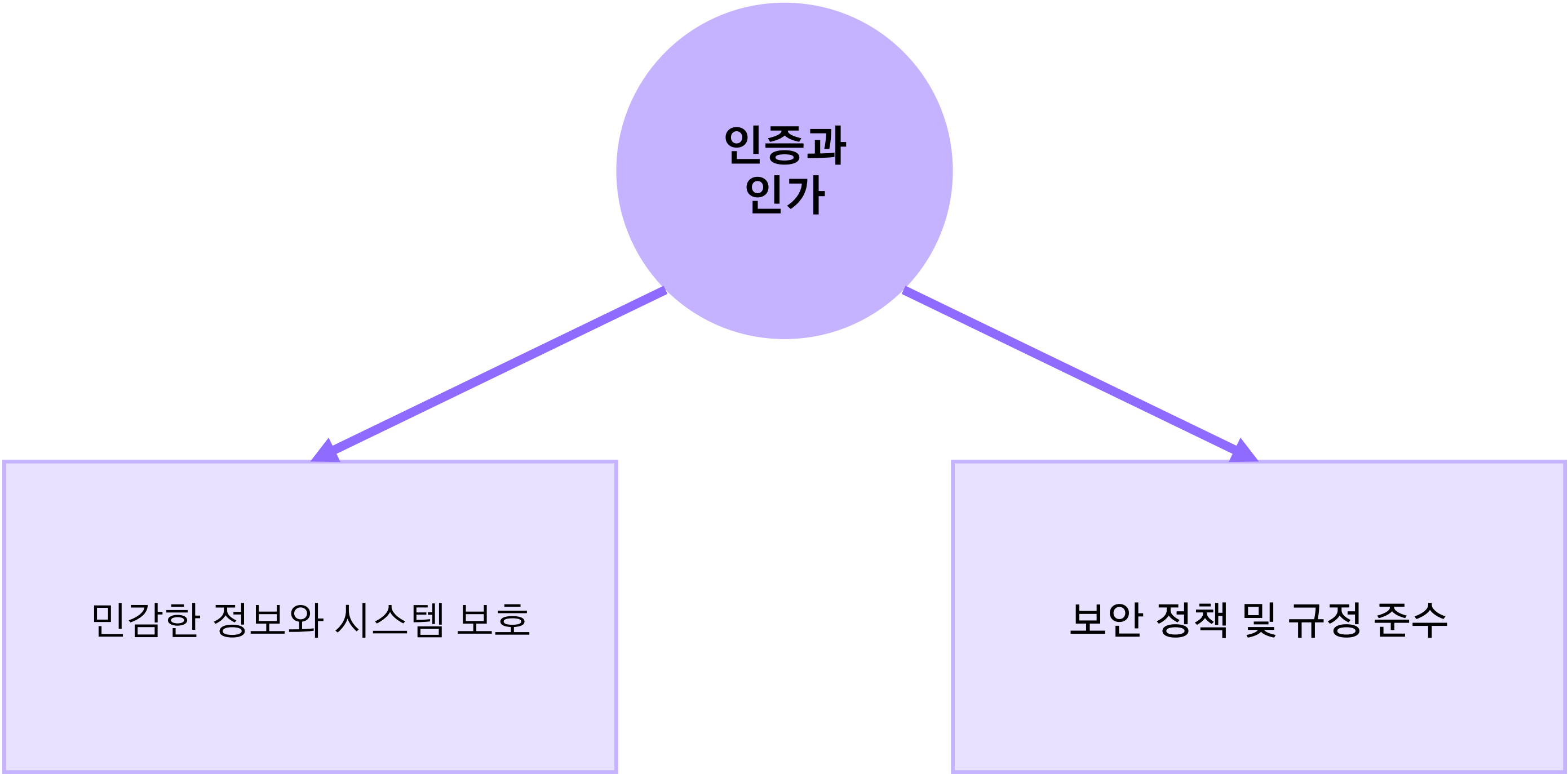


인증된 사용자가 어떠한 자원에 **접근할 수 있는지**를 확인하는 프로세스

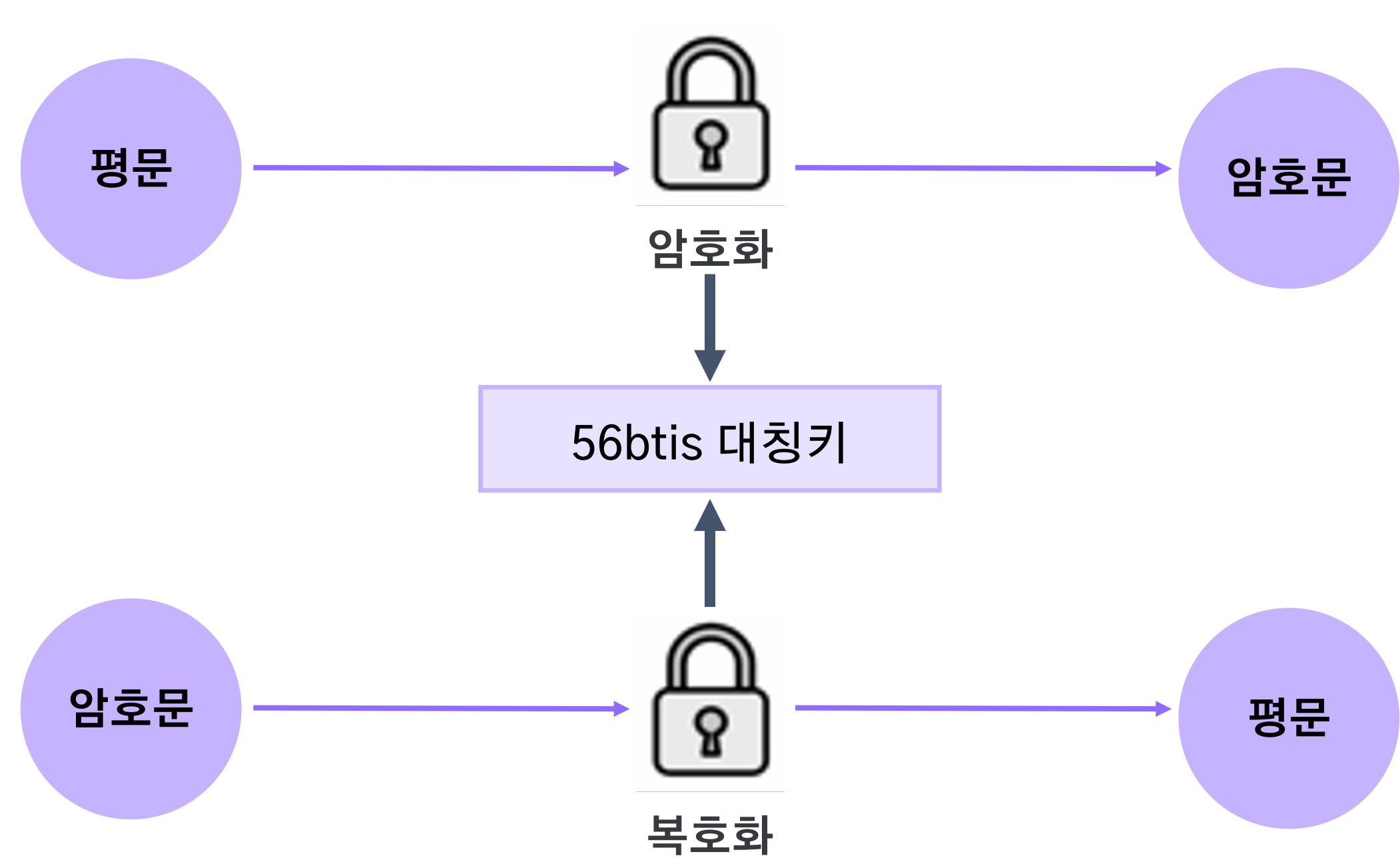
④ 인증과 인가의 차이

구분	인증	인가
기능	자격 증명 확인	권한 허가/거부
진행 방식	비밀번호, 생체인식, 일회용 핀 또는 앱	보안 팀에서 관리하는 설정 사용
사용자가 볼 수 있는가?	O	X
사용자가 변경할 수 있는가?	부분적으로 가능	불가능
데이터 전송	ID 토큰 사용	액세스 토큰 사용

④ 인증과 인가의 필요성

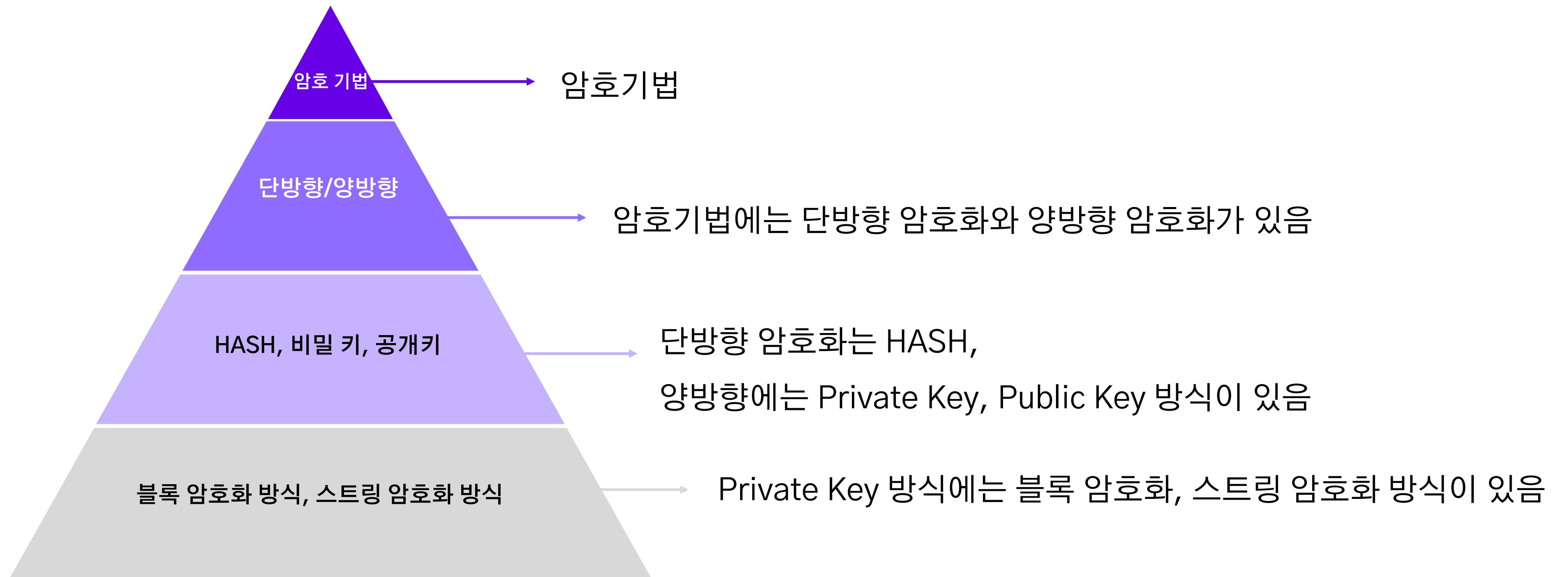


④ 암호 기법 구조



정보를 의도하지 않은 수신자가 파악할 수 없는 형태로 바꾸어 보호하는 학문

④ 암호 기법 구조



02

해시

☑ 해시(Hash)

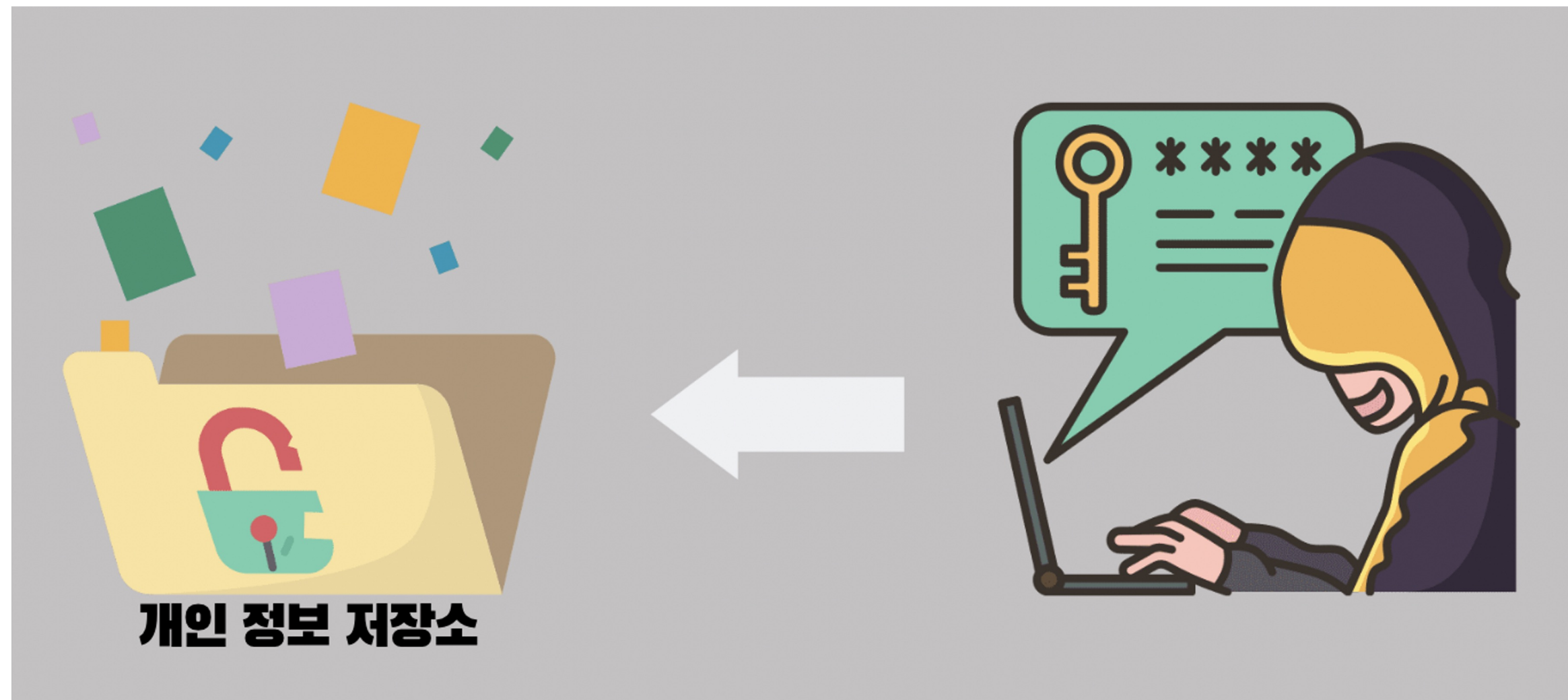
	내용
해시	단방향 암호화 기법으로 해시함수를 이용하여 고정된 길이의 암호화된 문자열로 바꿔버리는 것
해시함수	임의의 길이의 데이터를 고정된 길이의 데이터로 매핑하는 함수
해시값	매핑 후 데이터의 값
키	매핑 전 데이터의 값
해싱	매핑하는 과정

✍ 용어 해설

매핑
(mapping)

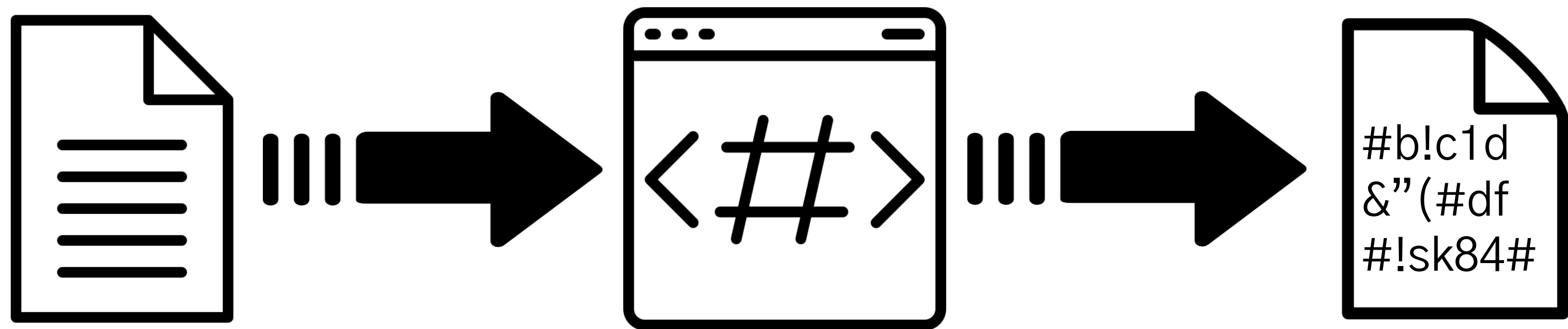
하나의 값을 다른 값으로
대응시키는 것.

④ 해시의 탄생 배경



각종 사이버 범죄와 해킹으로 인해 정보 유출 사건이 증가함에 따라
민감한 정보를 암호화하여 저장하기 시작함

④ 해시함수



임의의 긴 입력값을 적절하게 처리하여 짧은 값을 출력하는 함수

④ 해시함수의 종류

암호화 해시함수

해시값을 가지고 입력값을 알아내기 어렵다는 점을 이용하여 암호학적 원리기반

단방향성, 복호 불가 기능을 이용함

ex) MD5, SHA, MAC

비암호화 해시함수

동일한 해시값을 갖는 서로 다른 입력값은 존재하지 않는다는 해시함수의 성질을 이용하여

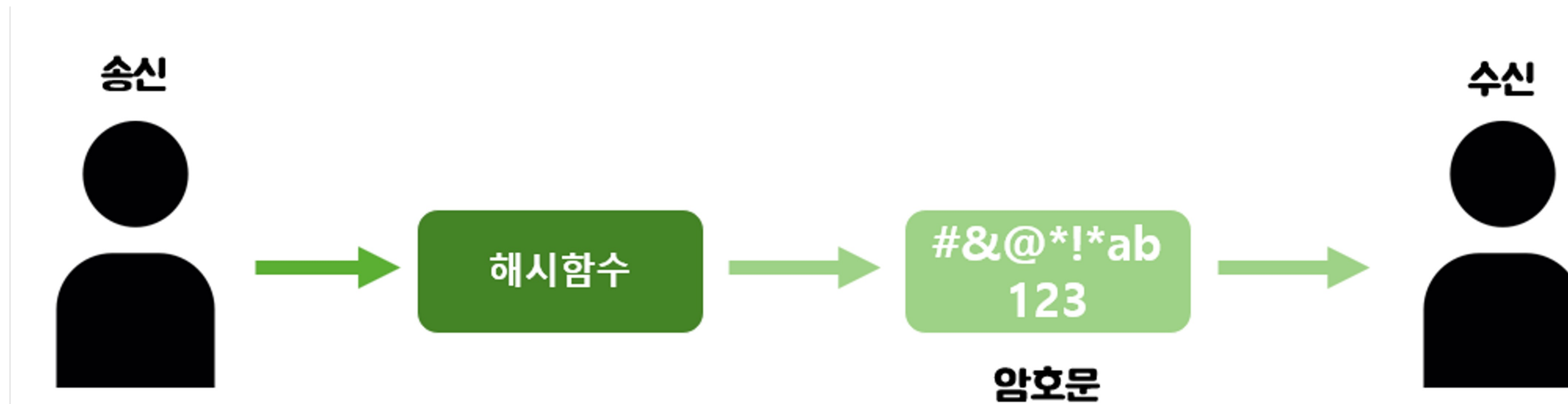
입력값에 대한 **무결성** 검증용

ex) CRC, Checksum

☑ 암호화 해시함수의 종류

알고리즘	이름	출력 크기	내부 크기	블록 크기
MD5	MD5	128 비트	128 비트	512 비트
SHA-1	SHA-1	160 비트	160 비트	512 비트
SHA-2	SHA-224	224 비트	256 비트	512 비트
SHA-3	SHA3-224	224 비트	1600 비트	1152 비트

☑ SHA(Secure Hash Algorithm)



서로 관련된 암호학적 해시함수 등의 모음

☑ 암호화 해시함수의 특징



④ 암호화 해시함수의 효과

압축 효과

해시함수가 반환하는 작은 해시값만으로도 거대한 크기의 데이터 무결성을 보장할 수 있는 효과

ex) SHA-256은 100GB의 파일 무결성을 256bit의 해시값으로 보장할 수 있음

눈사태 효과

아주 작은 변화로도 결과값이 전혀 다르게 도출되는 효과

또한 변경되는 부분에 있어 어떠한 규칙성도 찾을 수 없음

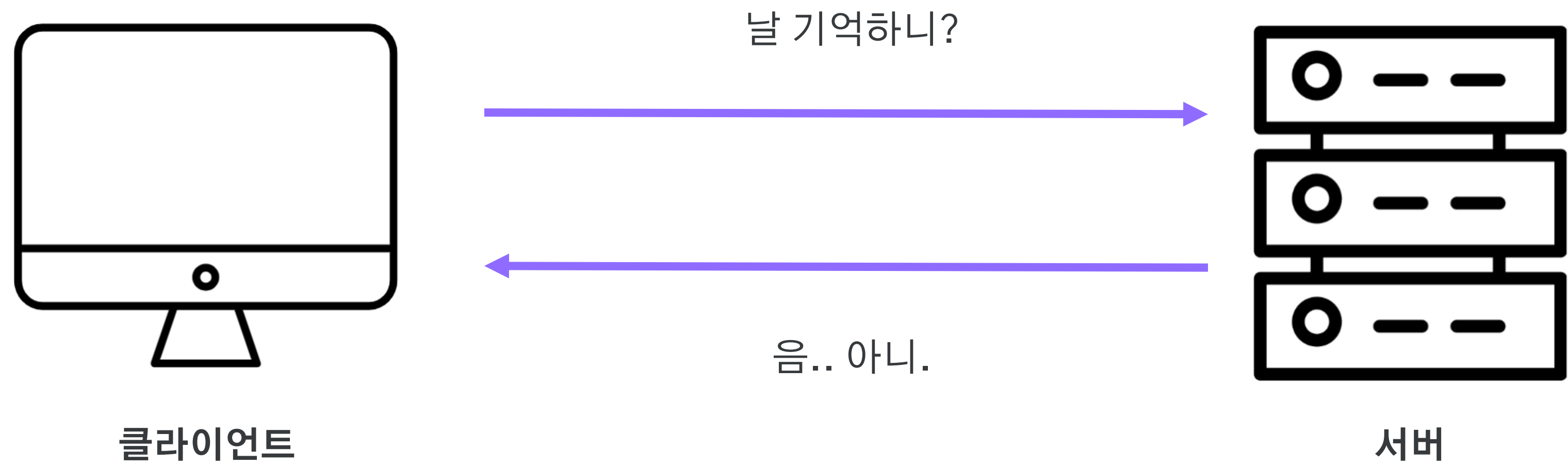
☑ 암호화 해시함수 활용 예시

활용 예시	내용
메시지와 파일 등의 무결성 검증	트랜잭션의 송신 전후, 메시지의 해시함수 결과값을 비교해 메시지나 파일에 대한 변경이 있었는지 확인할 수 있음
전자서명의 생성과 검증	메시지에 대한 암호학적 해시함수를 적용하도록 설계하여 상대적으로 작고, 안전하고, 계산적으로 원하는 크기의 메시지 해시함수 결과값을 생성
패스워드 검증	해시함수가 가장 보편적으로 활용되는 분야로, 패스워드 해시값을 저장함으로써 내부자 유출 시도 또는 해커의 공격 시에도 개인정보 노출 위험을 감소시킴

03

쿠키

✔ HTTP의 Stateless



☑ 쿠키(Cookie)



서버에서 사용자 브라우저로 전송하는 작은 데이터

☑️ 쿠키의 활용



[수능응원영상] ✨ 데이식스 - 한 페이지가 될 수 있게 ✨ COVER (문...
문산수억고 밴드부_SOUNDSCAPE
조회수 2.7만회 • 2개월 전



💡 새벽 힐링 모동숲 노래【3H】
루피 loopi
조회수 76만회 • 1년 전



라비(RAVI) - '유행 지난 춤' MV
GROOVL1N ✓
조회수 133만회 • 3개월 전

유튜브 추천영상이나 알고리즘등도 쿠키를 통해 만들어짐

④ 쿠키의 특징

- 한 개에 4KB까지 저장 가능하며, 최대 300개까지 저장할 수 있음
- 클라이언트에 저장됨
- 이름, 값, 만료날짜, 경로 정보가 들어있음
- 기본적으로 웹 브라우저가 종료되면 삭제됨

☑ 쿠키의 장·단점

장점

1. 기존 로그인을 위한 정보를 사용하기 때문에 인증 및 인가를 위한 추가적인 데이터 저장이 필요 없음
2. 서버 대수를 늘리는 **Scale-out**에도 크게 이슈가 없음
3. 사용자 로컬에 저장되는 만큼 서버와의 통신하는 과정을 없애기에 빠른 속도를 보여줌

단점

1. 사용자의 주요 정보를 매번 요청에 답아야 하기 때문에 보안상의 문제를 가지고 있음
2. 용량 제한이 있어 많은 정보를 담을 수 없음
3. 웹 브라우저마다 쿠키에 대한 지원 형태가 달라 브라우저 간 공유가 불가능함

🔖 용어 해설

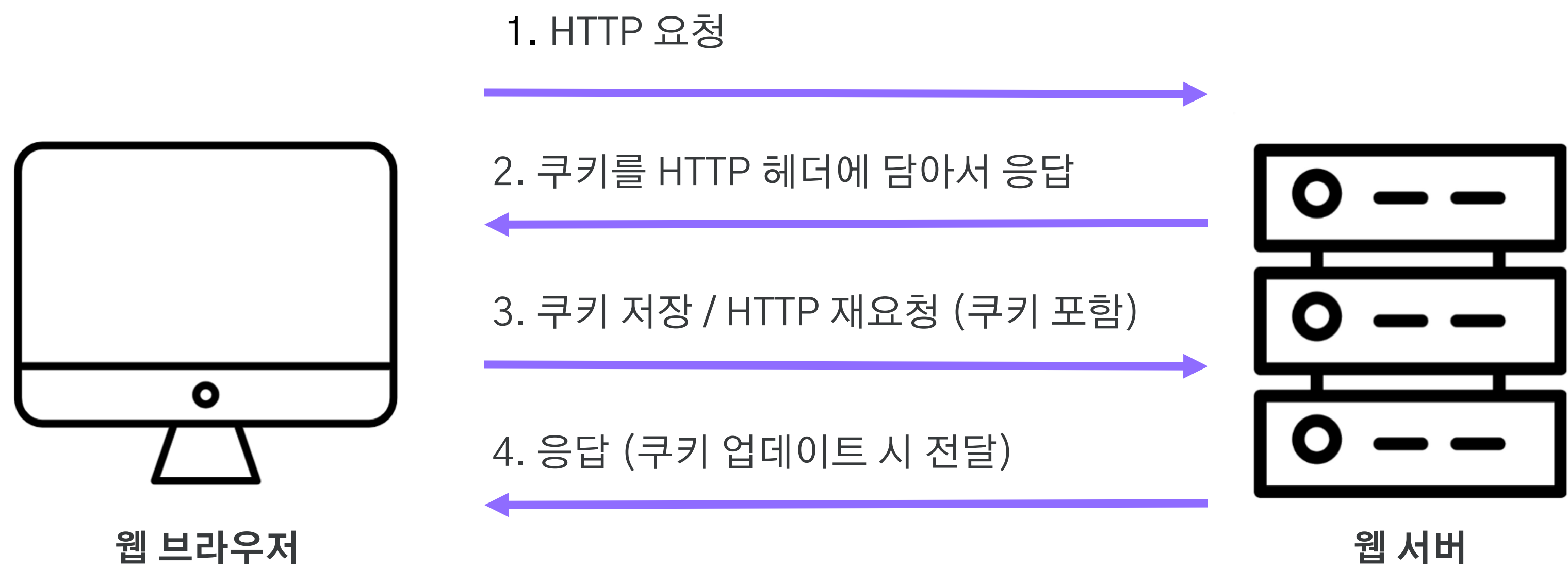
스케일 아웃 (scale-out)

서버를 여러 대 추가하여 시스템을 확장하는 방법.

☑ 쿠키의 종류

세션 쿠키(Session Cookie)	영구 쿠키(Persistent Cookie)
브라우저가 열려 있는 동안 유효함	하드디스크에 유효기간 동안 저장됨
서버를 이용하는 동안 사용자 정보를 유지하기 위해 사용됨	사이트 재방문 시 사용자 정보를 기억하기 위해 사용됨

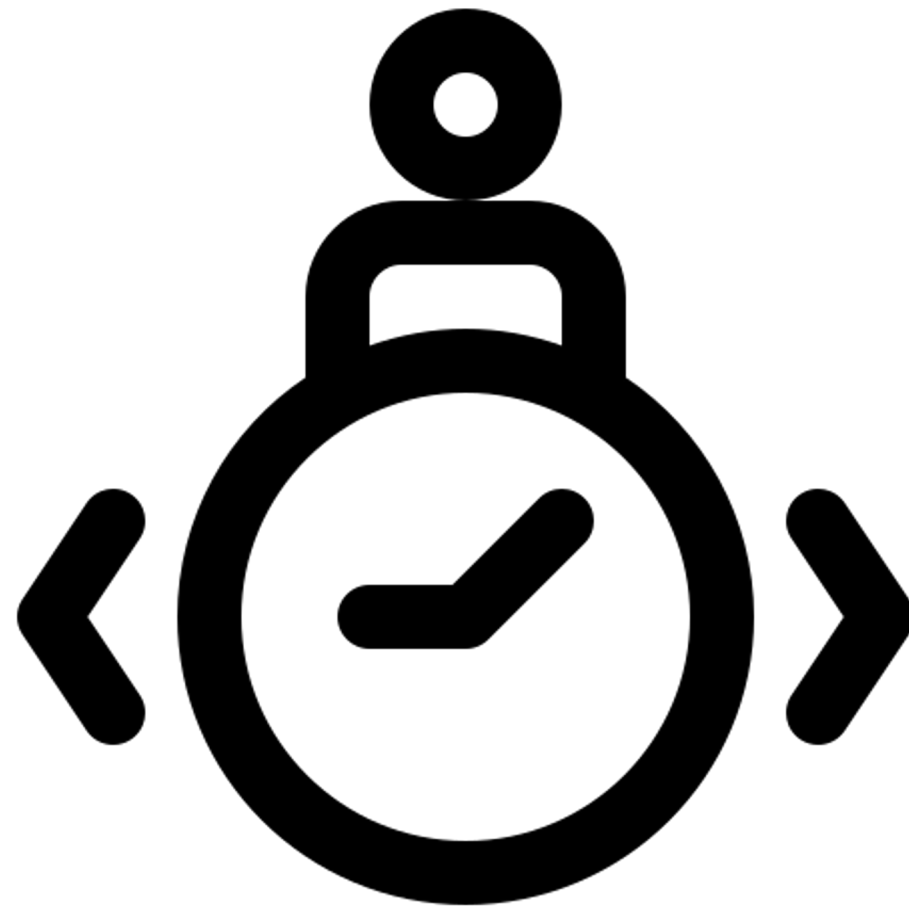
☑ 쿠키의 작동원리



04

세션

☑ 세션(Session)



웹 사이트의 여러 페이지에 걸쳐 사용되는 사용자 정보를 저장하는 방법

④ 세션의 특징

- 웹 서버에 웹 컨테이너의 상태를 유지하기 위한 정보를 저장함
- 웹 서버에 저장되는 쿠키 (= 세션 쿠키)
- 서버 용량이 허용하는 한에서 저장 데이터에 제한이 없음
- 각 클라이언트에 고유 Session ID를 부여함

④ 세션의 장·단점

장점

1. 쿠키에 비해서 안전함
2. 로그인 정보를 유지하여 자동 로그인 되는 기능이 있음

단점

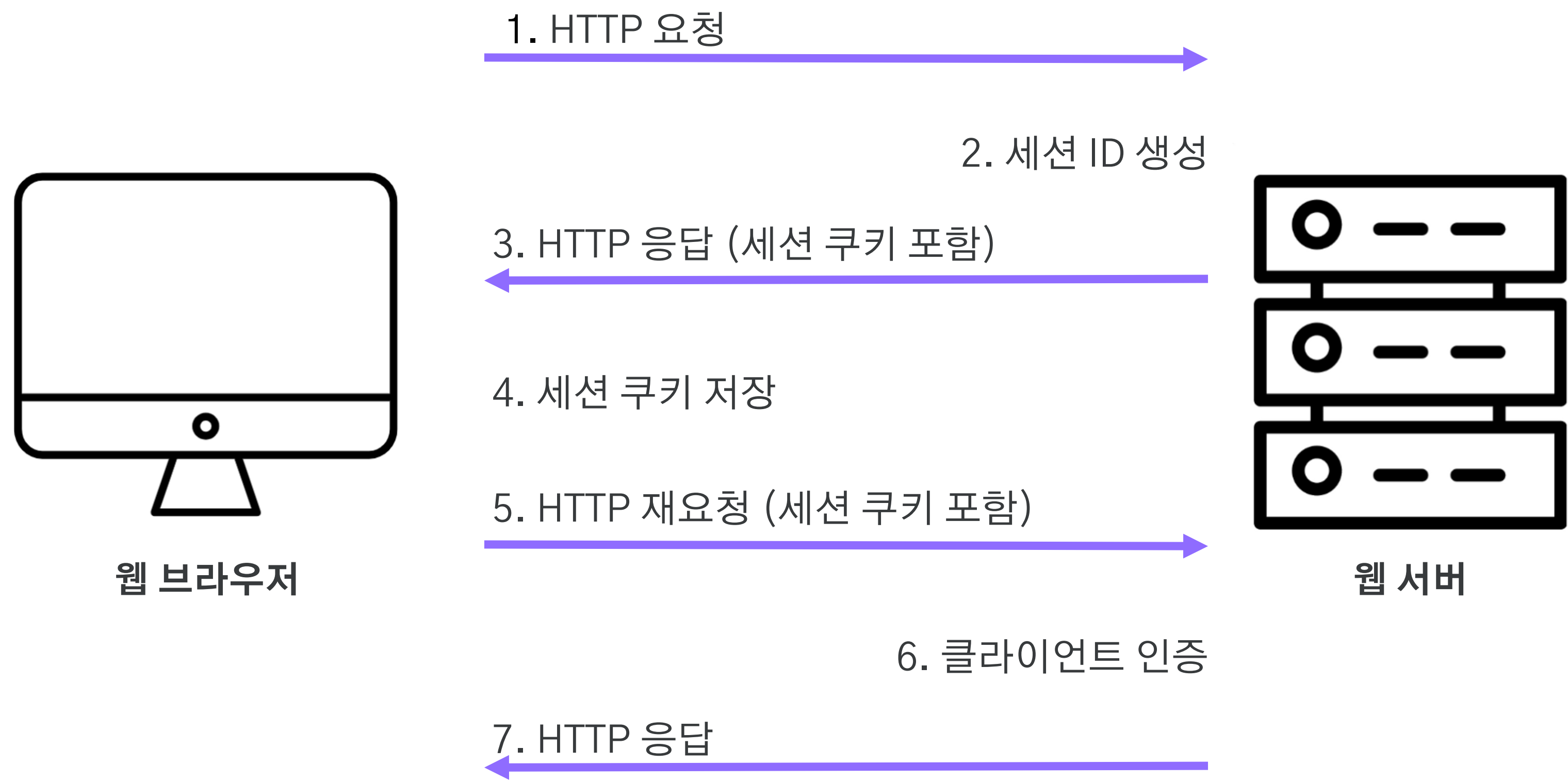
1. 쿠키에 비해 조금 느린 편
2. 한계가 존재하는 서버 자원을 사용하므로
속도 저하나 **오버헤드** 등 서버에 부하를 줄 수 있음

🔖 용어 해설

오버헤드 (overhead)

어떤 처리를 하기 위해 들어가는
간접적인 처리 시간·메모리 등.

④ 세션의 작동원리



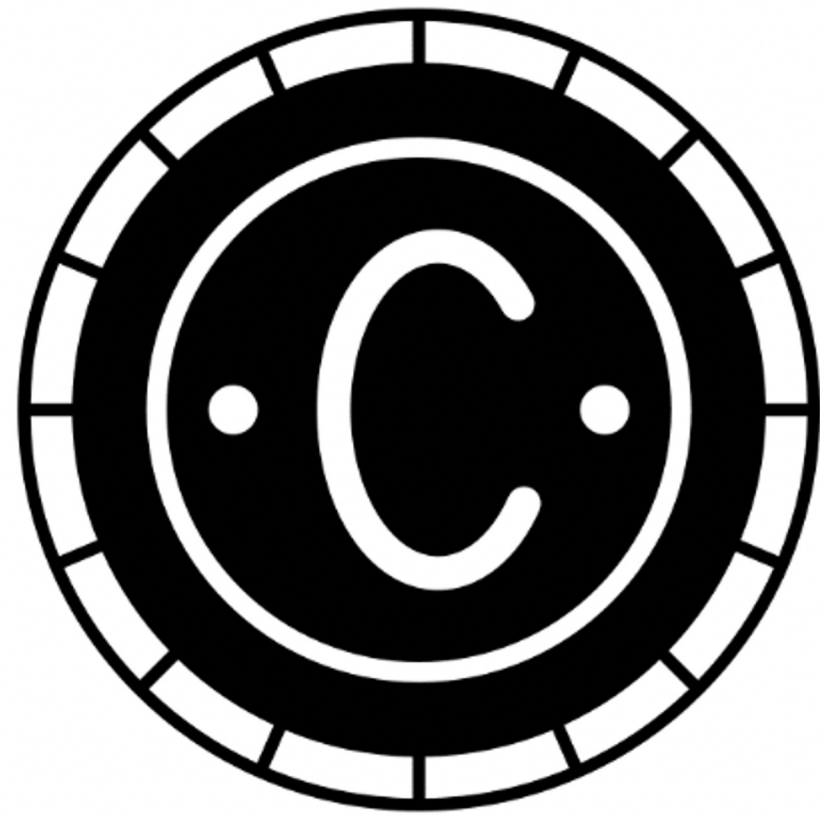
☑ 쿠키와 세션 비교

	쿠키	세션
저장 위치	클라이언트	웹 서버
만료 시점	쿠키 저장 시 설정 (브라우저가 종료되어도 만료 시점이 지나지 않으면 자동 삭제되지 않음)	브라우저 종료 시 삭제 (기간 지정 가능)
리소스	클라이언트 리소스	웹 서버 리소스
용량 제한	총 300개 하나의 도메인 당 20개 하나의 쿠키 당 4KB	서버가 허용하는 한 용량제한 X
속도	세션보다 빠름	쿠키보다 느림
보안	세션보다 안 좋음	쿠키보다 좋음

05

토큰

✔ 토큰(Token)

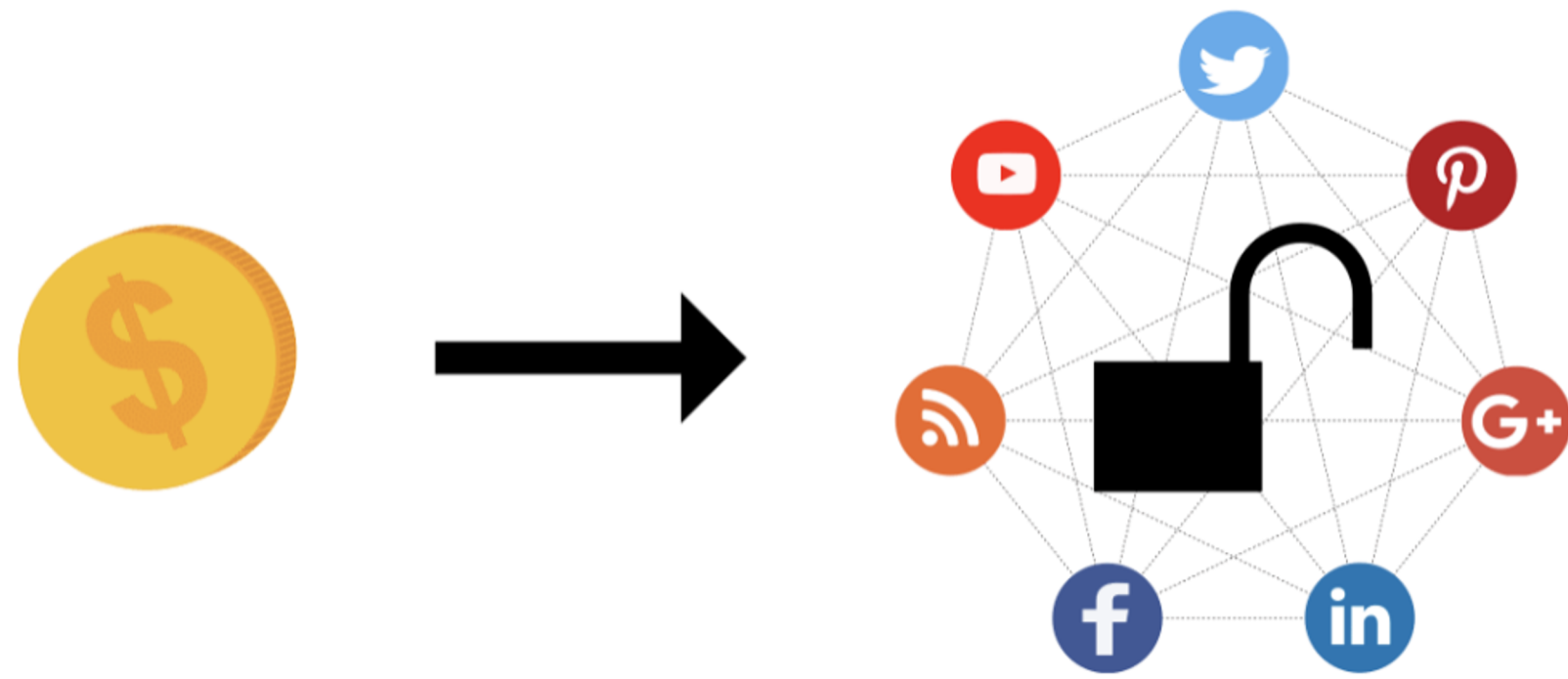


서버가 각각의 클라이언트를 누군지 정확히 구별할 수 있도록
유니크한 정보를 담은 **암호화 데이터**

☑ 토큰의 유형

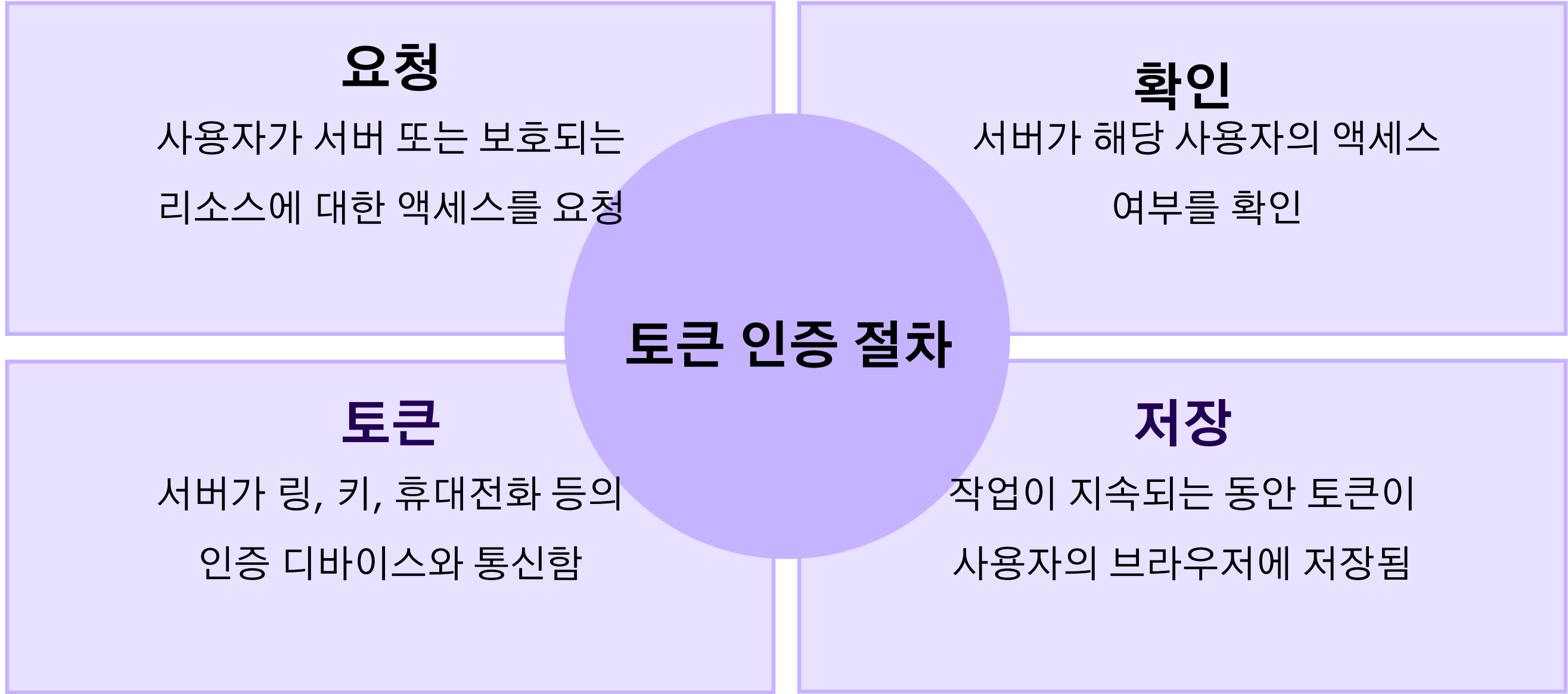
유형	내용
연결형	키, 디스크, 드라이브 및 기타 물리적 장치가 시스템에 연결되어 액세스를 허용함 ex) USB 디바이스, 스마트 카드
비접촉형	디바이스가 서버와 통신하려면 거리가 충분히 가까워야 하지만 연결을 할 필요는 없음 ex) Microsoft의 매직 링
분리형	디바이스가 다른 디바이스와 접촉하지 않고도 먼 거리에서 서버와 통신할 수 있음 ex) 이중 요소 인증 프로세스

④ 토큰 기반 인증



사용자가 자신의 아이덴티티를 확인하고 고유한 액세스 토큰을 받을 수 있는 프로토콜

👉 토큰 인증 절차



06

JWT

④ JWT(JSON Web Token)

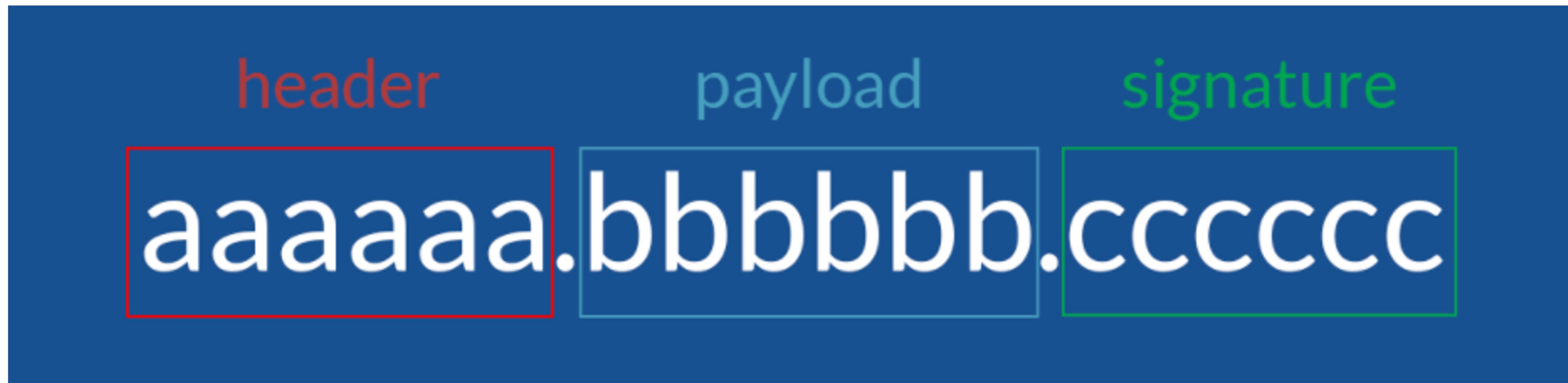


Json Web Token의 약자로 일반적으로 클라이언트와 서버 사이에서 통신할 때
권한을 위해 사용하는 토큰

④ JWT 특징

- JWT 토큰을 HTTP 헤더에 실어 서버가 클라이언트를 식별하는 방식
- JSON 데이터를 Base64 URL safe Encode를 통해 인코딩하여 직렬화한 것이며, 토큰 내부에는 위변조 방지를 위해 개인키를 통한 전자서명도 들어있음
- JWT를 서버로 전송하면 서버는 서명을 검증하는 과정을 거치게 되며 검증이 완료되면 요청한 응답을 돌려줌

④ JWT의 구성요소



- Header: 토큰 유형을 비롯해 관련된 서명 알고리즘을 정의
- Payload: 토큰 발급자, 토큰 유효기간 등을 정의
- Signature: 보안 서명을 통해 메시지가 전송 과정에서 바뀌지 않은 것을 확인

☑ 헤더(Header)

HEADER: ALGORITHM & TOKEN TYPE

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

JWT에서 사용할 타입과 해시 알고리즘의 종류가 담겨 있음

④ 내용(Payload)

PAYLOAD: DATA
<pre>{ "sub": "1234567890", "name": "John Doe", "iat": 1516239022 }</pre>

서버에서 첨부한 사용자 권한 정보와 데이터가 담겨있음

④ 서명(Signature)

VERIFY SIGNATURE

```
HMACSHA256(  
  base64UrlEncode(header) + "." +  
  base64UrlEncode(payload),  
  your-256-bit-secret  
) ☐ secret base64 encoded
```

개인키(Private Key)로 서명한 전자서명이 담겨있음

✔ JWT의 장·단점

장점

1. JSON 코드 언어로 생성된 토큰은 용량이 작기 때문에 두 **엔티티** 사이에서 매우 빠르게 전달됨
2. 거의 모든 곳에서 토큰이 생성될 수 있으며, 서버에서 토큰을 확인할 필요가 없음
3. 액세스 가능한 데이터, 권한 지속 시간, 로그인 시 가능한 작업을 지정할 수 있음

단점

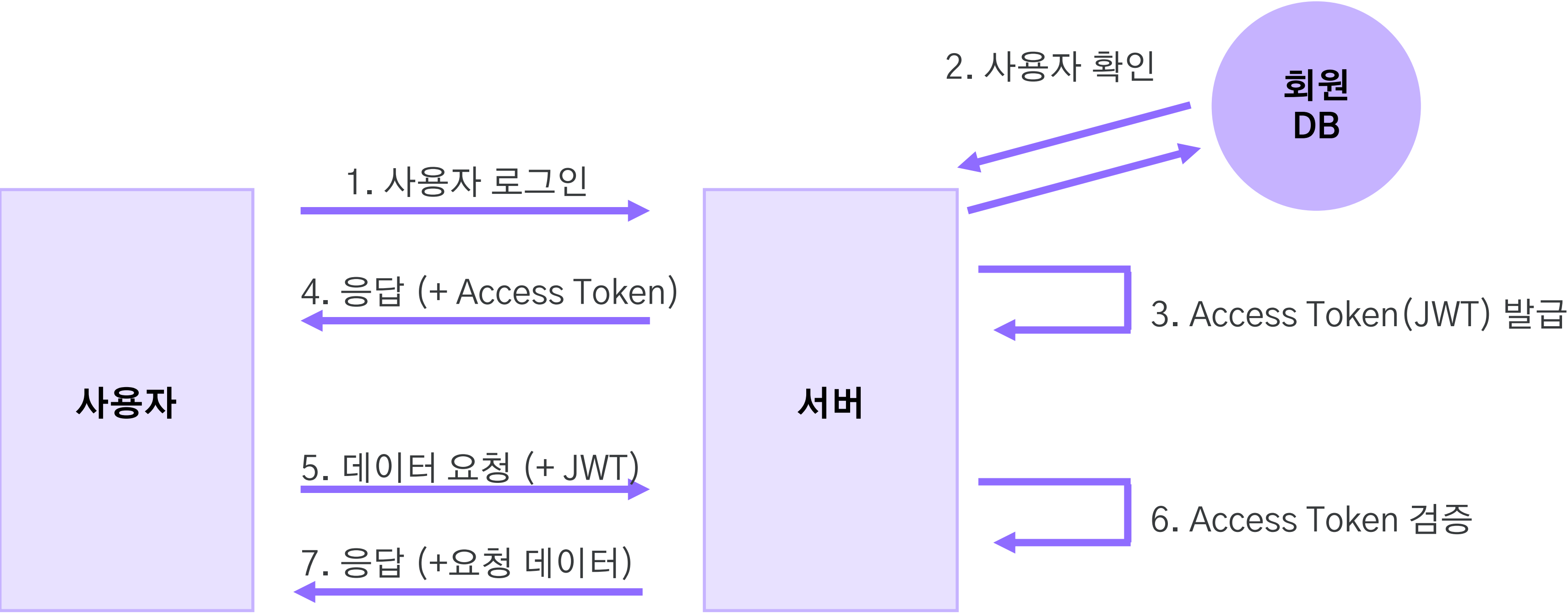
1. 단일 키를 이용하기 때문에 키가 유출되면 시스템 전체가 위험에 노출됨
2. 토큰이 복잡하기 때문에 개발자가 암호 서명 알고리즘에 정통하지 않다면 자신도 모르게 시스템을 위험에 빠뜨릴 수 있음
3. 메시지를 모든 클라이언트에게 푸시할 수 없고, 서버 측 클라이언트도 관리할 수 없음

✍ 용어 해설

엔티티 (entity)

데이터베이스에 표현하려고 하는 유형, 무형의 객체로서 서로 구별되는 것.

✔ JWT의 동작원리



👉 JWT 방식의 보완

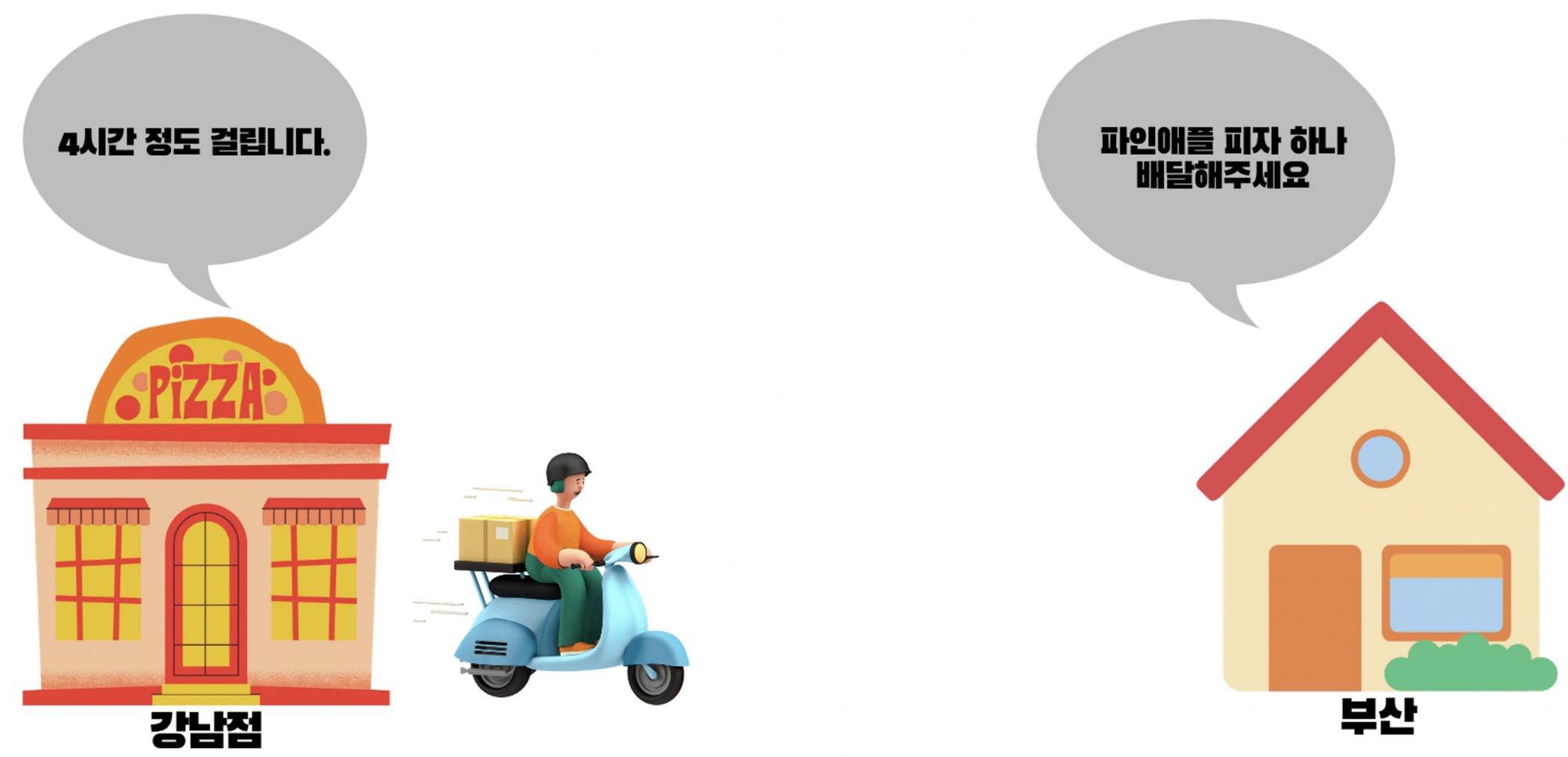
Refresh Token

- JWT를 발급할 때 Access Token과 함께 Refresh Token을 발급하여 Access Token의 짧은 만료시간의 문제를 해결하는 방법.
- Access Token은 1분, 3분의 짧은 시간을 부여하고 Refresh Token에는 일주일, 2주의 비교적 긴 만료시간을 부여하여 Access Token을 보장해줌.
- Access Token이 만료되면 Refresh Token으로 서버에게 새로운 Access Token을 발급하도록 함.

07

캐시

☑ 캐시(Cache)



자주 필요한 데이터나 값의 복사본을 일시적으로 저장, 보관하는 곳에 접근하는 방식

☑ 캐시의 특징

IOPS 증가

지연 시간을 줄일 뿐만 아니라 유사한
디스크 기반 데이터베이스에 비해 훨씬
높은 요청 속도를 제공

데이터베이스 비용 절감

단일 캐시 인스턴스는 수십만 IOPS를
제공할 수 있으며 따라서 수많은
데이터베이스 인스턴스를 대체할 수
있으므로 총 비용이 절감됨

애플리케이션 성능 개선

메모리는 디스크보다 훨씬 속도가 빠르기
때문에 인 메모리 캐시에서 데이터를 읽는
속도는 매우 빠름

백엔드 로드 감소

읽기 로드의 상당 부분을 백엔드
데이터베이스에서 인 메모리 계층으로
리디렉션함으로써 작업 급증 시에 작동이
중단되지 않도록 보호함

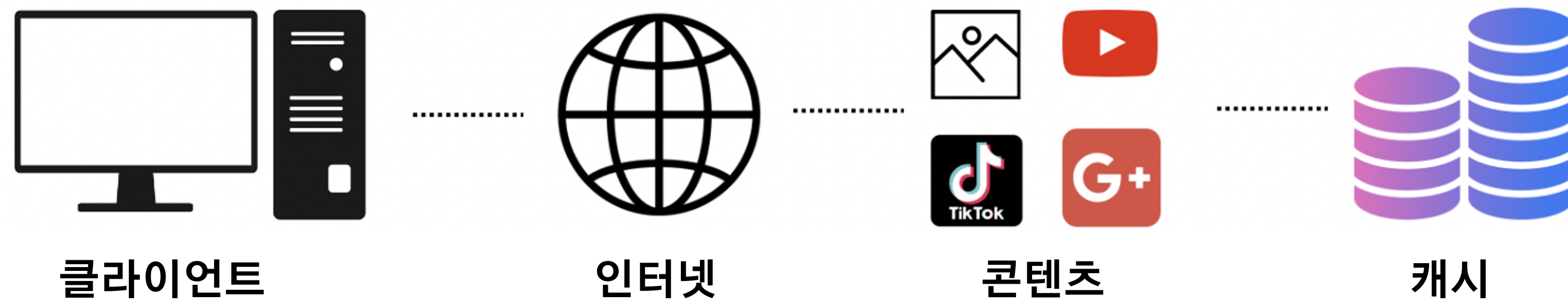


☑ 캐싱(Caching)



오랜시간이 걸리는 작업의 결과를 저장해서 시간과 비용을 필요로 회피하는 기법

☑ 캐싱 작동 방식



캐시의 데이터는 일반적으로 RAM과 같이 빠르게 액세스할 수 있는 하드웨어에 저장되며,

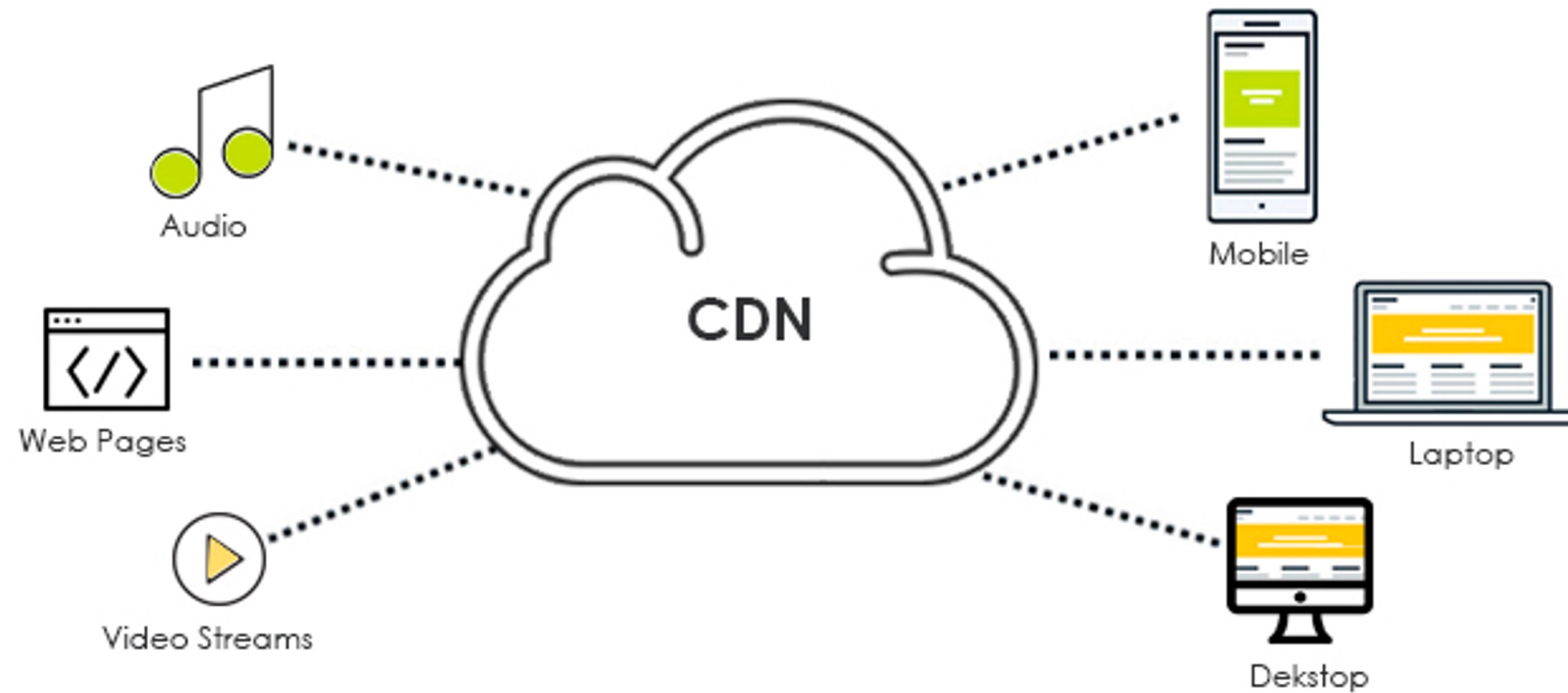
소프트웨어 구성 요소와 함께 사용될 수도 있음

액세스 해야하는 필요를 줄임으로써 데이터 검색 성능을 높이는 것

☑ 캐시와 쿠키 비교

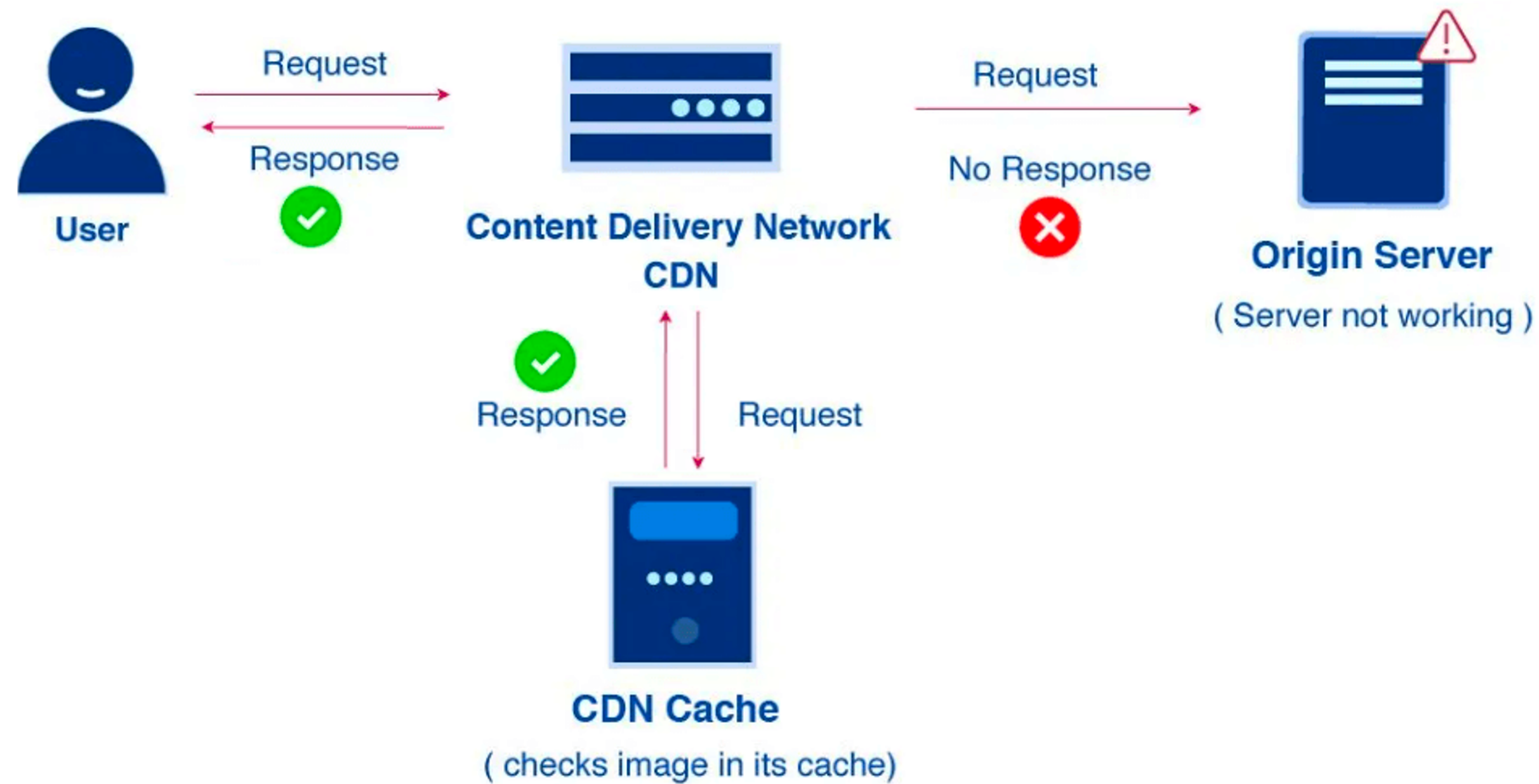
	캐시	쿠키
정의	웹 페이지 요소를 저장하기 위한 임시 저장소 (특히 후에 필요할 것 같은 요소들)	정보를 저장하기 위해 사용됨 (기본적으로 웹서버에서 PC로 보내는 작은 파일들)
목적	웹 페이지가 빠르게 렌더링 할 수 있도록 도와줌	사용자의 인증을 도와줌
삭제	사용자가 직접 수동으로 삭제 해주어야 함	만료 기간이 있어 시간이 지나면 자동 삭제됨
예시	오디오, 비디오 파일 등	로그인 정보, 방문 기록, 방문 횟수

☑ CDN(Content Delivery Network)



고용량 데이터를 이용자가 어느 곳에 위치해 있더라도 안정적으로 전송해주는 기술

④ CDN의 구성



CDN 기술은 CDN 네트워크와 Cache서버가 위치함

④ CDN의 장·단점

장점

1. 글로벌 범위 안에서 장거리 웹 사이트 로딩 속도 개선과 함께 안정적인 콘텐츠 제공이 가능
2. 전세계의 인프라와 별도의 서비스 제공 업체에 투자하는 대신 글로벌 CDN을 사용하면 호스팅에 많은 비용을 지불할 필요가 없으므로 비용을 절감할 수 있음

단점

1. 특정 국가나 지역만을 타겟으로 하는 웹 서비스를 운영할 경우 CDN을 이용하면 오히려 불필요한 연결 지점이 늘어나 웹 사이트의 성능 저하를 불러올 수 있음
2. CDN을 위한 Cache Server들이 많이 보유되지 않거나 성능이 안정적이지 않다면 최악의 경우 SPOF(단일 장애점) 문제가 발생할 수 있음

☑ CDN의 활용

활용 사례	사례 설명
콘텐츠 캐시 서버	구글캐시, 웹사이트,유튜브 콘텐츠를 현지 통신사 캐시 서버에서 제공
클라우드 스토리지	AWS S3, 스토리지 데이터를 근접 리전에서 클라우드 서비스로 제공
멀티미디어 스트리밍	넷플릭스 오픈커넥트, 현지 ISP와 협력하여 멀티미디어 트래픽 로컬화